

없는 것보다 주석 처리된 것이 위험합니다

보고에 결가지로 적힌 한 줄이 이번 턴의 순서를 바꿨습니다 — 「@path_permission이 주석 처리되어 있습니다」. 권한이 없으면 「아직 안 붙였다」로 읽히지만, 주석은 「한때 붙어 있었다」는 뜻입니다. 누군가 꺾고, 그 이유가 사라진 뒤에도 꺼진 채 남았을 수 있습니다.

D-334 · 이번 턴 최우선

그리고 코드를 읽는 사람에게는
붙어 있는 것처럼 보입니다

이것이 착시의 가장 나쁜 형태입니다. 표를 만드는 일보다 먼저입니다. 코드를 읽어서 답하지 말고 호출해서 확인하고(D-210), 열려 있으면 즉시 잠그고 사고로 기록하며, 같은 것이 다른 곳에도 있는지 전수로 세심시오(분모 출력).

399

passed (직전 357)

27 / 39

계약 절 구현 69% 실측

610건

임계값 전수 · 계약면 127

v3.1 → v3.2

144 → 150

주석 처리된 권한 — 전수 조사

"...다만 F-05 진입면에 연결되어 있지 않고
@path_permission이 주석 처리되어 있습니다."

이 문장은 **잔여 절 계산의 결과**로 적혀 있었습니다. **그러나 이견 진척 보고가 아니라 보안 사안입니다**. 표를 만드는 일보다 먼저라 이번 턴의 ①번 자리를 여기로 옮깁니다.

- 1 그 라우트가 지금 인증 없이 접근 가능한가. 다른 계층(미들웨어·라우터 설정)이 막고 있는가 → **호출로 확인하라. 코드를 읽어서 답하지 마라** D-210 **실측 우선**
- 2 git blame으로 주석 처리 시점과 함께 들어간 변경을 본다. 경위를 사실로 적는다. 추측 금지 D-280
- 3 열려 있으면 즉시 잠근다. 그리고 사고로 기록한다 — 되돌림이 아니라 기록이다.
닫혀 있으면 무엇이 막고 있는지를 시험으로 고정한다 — 「지금은 안전하다」는 진술은 증거가 아니다 D-105
- 4 ★ **부작위 전수** — 주석 처리된 권한·인증 데코레이터가 다른 곳에도 있는가. @path_permission만이 아니라 **권한 계열 전부**. 분모를 출력하라. 나는 그 수를 모른다 — **실측**으로 답하라 D-300 · D-301

도구 verify_commented_guard.py

D-286 · D-310

- 권한·인증 계열 데코레이터가 주석 상태로 존재하면 exit 1
- 기존분은 D-311 래치 — 단, ③에서 「열려 있음」이 나온 건은 래치 대상이 아니다. 즉시 고친다
- D-310 자기표본 필수 — 이번에 찾은 그 줄을 fixture로 박아라

§ D-338 · 그리고 착시 ⑥이 재발하기 직전입니다

카메라 39대 중 39대 미입력 **실측**. 계측기는 있습니다. 그러나 지금 install_address는 **정의 있음·읽기 있음·쓰기 0** 곳입니다.

★ 이견 D-304 착시 ⑥(스키마의 착시)의 정확한 형태입니다. clip_path가 그랬습니다. 계측기가 「39/39 미입력」을 출력하니 **숨지는 않습니다. 그러나 숨지 않는 것과 살아 있는 것은 다릅니다**.

#	이번 턴에 함께 한다	왜
①	채우는 수단을 먼저 만든다 — 관리자 U는 나중이어도 좋으나 커맨드나 API로 지금 채울 수 있어야	쓰기 지점 0곳을 넘긴 채로 턴을 마치지 마라
②	E2E 픽처에 주소가 채워진 카메라를 넣고, 알림 위치줄에 그 주소가 실제로 나가는 것을 시험이 본다	「필드를 만들었다」가 아니라 「이 경로로 사람에게 도달한다」가 증명된다
③	미입력 39건은 운영 항목 으로 등재 — blocked_now: false · 유형 OPS · 소유자 고객사	개발 잠금이 아니다. 설치 위치를 아는 쪽이 아는 값

verify_dead_fields.py 화이트리스트에 **넣지 마십시오**. ①이 끝나면 쓰기 지점이 생기므로 넣을 이유가 없습니다. ★ 이번 턴이 끝났는데도 쓰기 0 곳이면 그 게이트가 빨개져야 정상입니다.

F-05 인증 — 만들지 않고 있습니다

방식: 헤더 API Key. OAuth2-JWT는 과합니다 — 상대는 서버-투-서버 기계이고, 계약 상대는 **인용·계약** 에스비 한 곳입니다. 사람 로그인이 없습니다.
★ 과한 인증은 안전을 주지 않고 연동 실패를 줍니다. 상대가 못 붙이면 F-05는 초록이어도 **죽은** 면입니다.
선행은 D-334입니다 — 열린 문을 두고 문패를 정하지 않습니다.

§1 규약 다섯 — 전부 시험으로 건다

#	규약	시험이 확인하는 것
①	키는 테넌트에 묶인다	키로 들어온 요청은 그 테넌트 범위 밖을 절대 못 본다. 남의 자원 요청은 404 — 403 아님, 존재도 알리지 않는다(D-269)
②	HTTPS 강제	평문 요청 거부. 키가 평문으로 흐르면 키가 아니다
③	읽기 전용부터	지금 여는 것은 이벤트 조회뿐. 쓰기 면은 절 을 따로 세운다 — 계약 AC 절에 쓰기가 있는지 절 표에서 먼저 확인. 없으면 만들지 마라
④	키 값은 저장하지 않는다	해시만 둔다. 조회는 언제나 마스킹 (D-204 · 표 ②와 같은 규약)
⑤	부작위(D-300)	키 인증을 통과한 요청이 원본 영상·타 테넌트 식별자에 닿는 경로가 0건 임을 시험한다

§2 발급·폐기는 만들지 않는다 — 네가 찾은 것을 쓴다

```
core.apikey_account (dj-core)
★ §0.4 금지구역이다. 수정하지 마라.
# 다만 D-207 은 수정 금지이지 사용 금지가 아니다 - 읽고 호출하는 것은 허용.
# 확장이 필요하면 우리 층에서 감싼다(L3 어댑터). 금지구역 안으로 손을 넣지 마라.

third_api/views/api_key_controller.py ← 우리 것. 여기에 있네다
```

★ 이견 D-333("밖을 사기 전에 안을 뒀진다")의 안쪽 판입니다:
밖을 사기 전에 안을 뒀지고, 만들기 전에 이미 있는지 뒀진다.
「남은 일은 만들기가 아니라 잇기」 — 네 문장을 그대로 정본으로 올립니다.

D-336 네가 스스로 더한 것 — 전면 승인한다

원칙 승격

「없으면 '임계값을 설정 가능하게 만들었다'가 곧 '계약 AC를 설정 가능하게 만들었다'가 된다」 — 제가 놓쳤고 네가 잡았습니다.
확장: 409로 멈추는 것만으로는 부족합니다. ★ 게이트가 **contract_fixed** 항목의 값이 계약 AC 원문과 일치하는지 검사하십시오 — **인용·계약** F-04 「5분」·F-10 「30초」에서 벗어나 있으면 **exit 1**. 런타임 덮어쓰기는 409가 막고, 저장된 값 자체가 틀린 것은 게이트가 막습니다. 둘 다 필요합니다.
각 항목에 **절 번호**를 링크하십시오 — 계약이 바뀔 때 무엇을 고쳐야 하는지 사람이 찾지 않아도 됩니다.
원칙: 설정 가능성은 기능이 아니라 위협이다. D-324(금지선은 행위에)의 이웃입니다 — 유연성도 금지선이 필요합니다.
「다르게 보시면 판정 주십시오」에 답합니다: 다르게 보지 않습니다. 앞으로도 이런 것은 묻기 전에 넣으십시오. 넣고 사유를 적으면 제가 뒤에서 판정합니다 — 그 반대는 네가 아는 것을 내가 모르는 채로 시간만 씁니다.

제 수 셋이 틀렸습니다

#	제 수	무엇이 틀렸나
①	잔여 추정 10절 → 실측 12절	표 ②가 F-05-F-12의 「API키」 두 절을 값을 것으로 봤는데 방향 이 반대였다. 표 ② = 나가는 키(우리가 남의 API를 부를 때) · FR-05-3 = 들어오는 키(남이 우리 OpenAPI를 부를 때)
②	막는 것 추정 3건 → 실측 4건	나는 FX-5를 DEV 잠금으로 놓고 계산했는데, 대장의 DEV 3은 VIDEO-ZONE· 빈DB 였고 FX-5는 ADMIN 한 줄이었 다. ★ 나는 대장을 읽지 않고 기억으로 계산했다
③	「결정 v3.0(138)」	태그가 없었고 틀렸다. 저장소는 v2.9(132)였다. ★ D-322를 만든 바로 그 문서에서 태그를 빼뜨렸다

③은 규약이 첫 턴에 자기 저자를 잡은 것입니다 — D-310(도구는 자기가 태어난 표본을 시험에 넣는다)의 사람 판. **잘 잡았습니다**.
②에서 원칙 하나: 대장의 수를 기억으로 쓰지 않는다. 인용하거나 **추정**을 단다. 예외 없다.
확인 1건 — 「빈DB」가 무엇인지 저는 모릅니다. 한 줄로 알려 주십시오. 사유에 따라 순서를 다시 봅니다.

§ ★ 신설 — 「같은 이름, 다른 것」 대장

이름의 유사성으로 오판한 것이 세 번째

이름	갈래 A	갈래 B	구분 기준
CCTV·재난안전정보 D-321	설치 위치 메타데이터	우리가 받는 영상	대상 — 목록인가 스트림인가
juso 승인키 D-328	팝업 UI 위젯	서버 조회 API	주체 — 브라우저인가 서버인가
API Key D-337	나가는 키 우리가 남의 API를 부를 때	들어오는 키 남이 우리 API를 부를 때	방향 — outbound인가 inbound인가

규칙 — 이름이 겹치는 것을 발견하면 **즉시 등재**합니다. 그리고 코드·대장·문서에서 **그 이름을 단독으로 쓰지 않습니다** — 반드시 방향이나 주체를 붙여 씁니다(inbound_api_key / outbound_api_key).
강제 도구 — 대장에 오른 이름이 **수식어 없이 새로 등장하면 exit 1**. 기준본은 래칭(D-311).

D-339 커밋 1건 승인 — D-327 슬어대로

승인

「결정문·표·게이트 셋·기준선·대장이 한 되돌림 단위라 1커밋」 — **웁습니다**. 진행하십시오.
본문에 D-322-333을 적고 **v3.1(144)** 도달과 그날의 수(399 passed · 절 27/39)를 함께 적으십시오. 태그는 붙이지 않습니다 — rc-sdn-excl-0.1 이후 릴리스 후보 조건이 다시 차지 않았습니다.

실행 순서 — 보안이 ①번입니다

구현 27절 · 69% 미착수 4절 잠김 8절 · SDN·영상재생·구역판정

계약 기능 39절 **실속**

- 1 D-334-339 정서 — v3.1/144 → v3.2/150 · 각 결정문에 강제 도구 기입 D-286
- 2 ★★@path_permission 조사 — 이번 턴 최우선. 호출로 확인 → git blame → 열려 있으면 즉시 잠금 → 권한 계열 주석 전수(분모 출력) D-334
- 3 커밋 1건 — ②의 결과가 「즉시 고침」을 포함하면 그것까지 같은 커밋에 D-339
- 4 F-05 진입면 잇기 — 규약 다섯을 시험으로. 만들지 말고 이어라. dj-core는 읽고 호출만, 확장은 우리 층에서 감싼다 D-335
- 5 카메라 주소 실효화 — 채우는 수단 + E2E 픽스처 + 운영 항목 등재. 쓰기 0곳으로 턴을 마치지 마라 D-338
- 6 contract_fixed 게이트 확장 — 표 값이 계약 AC 원문과 어긋나면 exit 1 · 절 번호 링크 D-336
- 7 동음이의 대장 신설 + 기존 3건 등재 · inbound_/outbound_ 명명 정정 D-337
- 8 「빈DB」 잠금이 무엇인지 한 줄 회신 확인 1건
- 9 절 표 재발행 — **실속**으로. 미착수 4 → ?절 · 잔여 12 → ?절 이번 턴의 결과물
- 10 여기서 멈춘다. ⑨를 보고 최종 관문(통합시험 준비 완료)의 정의를 내가 확정한다 보고 후 판정

※ 관리자 UI(팝업 API 연결)는 ⑤의 ①이 커맨드로 대체되므로 여전히 우선순위 낮음. · ※ VIDEO 구간 추출 · ZONE 폴리곤은 잔여 절 안에 있습니다. ⑩에서 순서를 정합니다.

§ 대표개 — 보고 두 줄과 부탁 하나입니다

- ① 진척이 숫자로 보입니다. 계약 기능 39개 절 중 27개가 구현되어 증명 시험까지 붙었습니다(69%) **실속**. 시험은 399건이 통과합니다. 잔여는 12개 절이고, 그중 8개는 SDN·영상재생·구역판정에 묶여 있습니다.
- ② 보안 점검 하나를 최우선으로 돌립니다. 코드에 권한 검사가 주석 처리된 자리가 발견됐습니다. 지금 실제로 열려 있는지는 아직 모릅니다 — 다른 층이 막고 있을 수도 있습니다. 추측하지 않고 호출해서 확인하도록 지시했고, 열려 있으면 즉시 막고 사고로 기록합니다. 다른 곳에도 같은 것이 있는지 전수로 셉니다. 진척보다 이것을 앞에 놓았습니다.
- 부탁 하나 — 안양 카메라 39대의 설치 위치 목록이 있으면 주십시오.
어제 말씀드린 「카메라에 주소를 적어 둔다」가 코드로 썼는데 39대 전부 비어 있습니다. 이걸 우리가 만들 수 없는 정보입니다 — 현장을 아는 쪽이 아는 값입니다.
· 지금 당장은 없어도 됩니다. 개발·시연용은 Code가 표본을 채워 증명합니다
· 다만 실제 납품 시에는 한 번 채워야 하는 값이라, 목록이 있으면 지금 넣어 두는 편이 낫습니다
· 형식은 자유입니다 — 「카메라 이름 / 도로명주소 / 현장 표현(정문·3층 복도 등)」 세 칸이면 충분합니다
- SDN은 회신 지연 일수가 매 실행 화면에 뜨고 있습니다. 계약 6조3항 기산은 이미 서 있으니 따로 하실 일은 없습니다.